

AMIS 1012

Ethics in Computing



Chapter 6: Risk Assessment and Trustworthy Computing



Learning Objectives

— — —

1. Explain the purpose and the steps of security risk assessment.
2. Provide the core principles of trustworthy computing: security, privacy, reliability, and business integrity.
3. Compare and contrast core principles of the CIA Triad—Confidentiality, Integrity, and Availability.
4. Discuss the importance of IT Security Policy.
5. Describe the role of International Organization for Standardization (ISO) and the scope of ISO 27001.
6. Describe the role of National Institute of Standards and Technology (NIST) and the scope of NIST Cybersecurity Framework (NCF).



Chapter Outline

- — —
- 1. General Security Risk Assessment
- 2. Trustworthy Computing
- 3. CIA Triad
- 4. IT Security Policy
- 5. International Organization for Standardization (ISO)
- 6. National Institute of Standards and Technology (NIST)





1. General Security Risk Assessment

— — —

- A risk assessment is a method for determining the security risks that an organisation's systems and networks face from both internal and external threats.
- The aim of risk management is to determine which time and capital expenditures can help defend the company from its most possible and significant threats.



1. General Security Risk Assessment

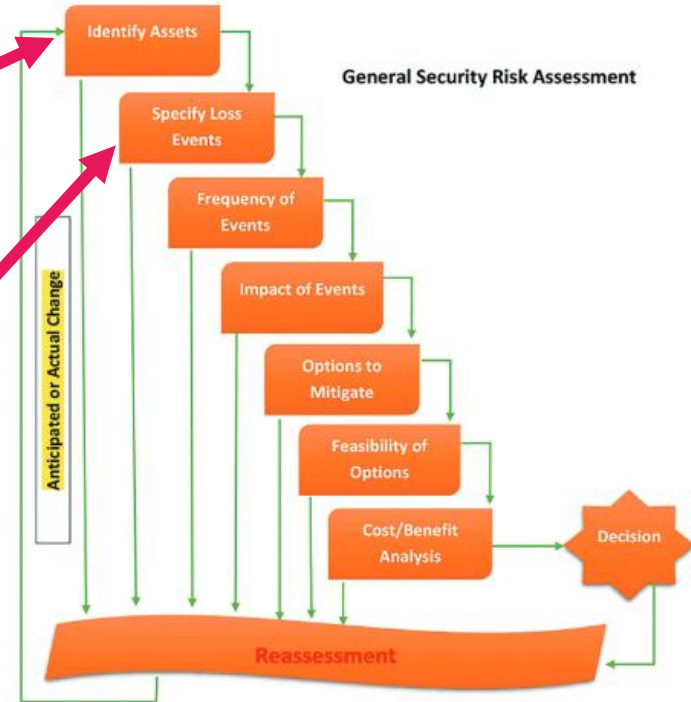
— — —

- An asset is any hardware, software, computer system, network, or database that is used by the enterprise to accomplish its business goals in light of an IT risk evaluation.
- A failure case is any event that has a detrimental effect on an object, such as a device being infected by a virus or a website being targeted by a DDoS attack.

1. General Security Risk Assessment

The following are the steps in a general security risk evaluation process:

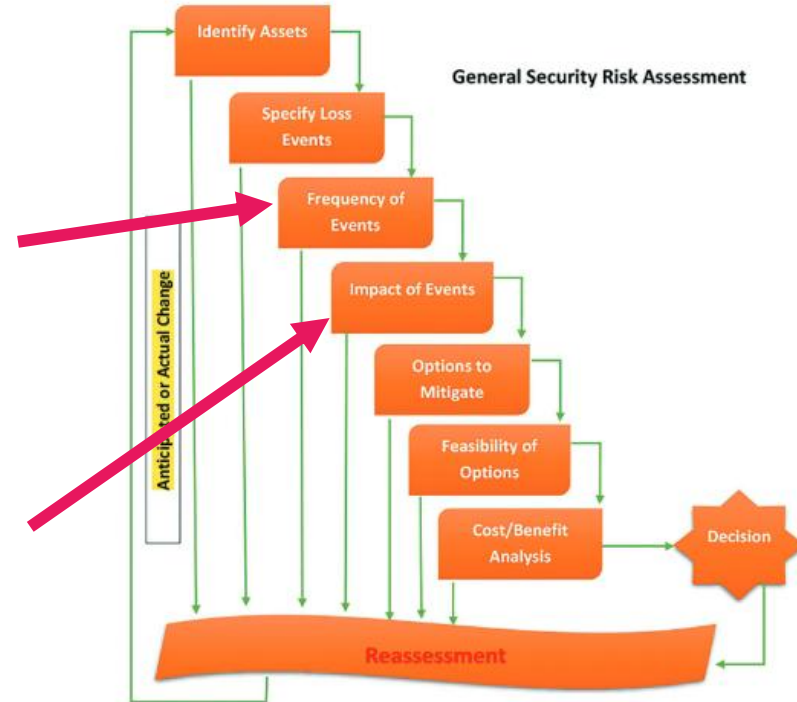
- Step 1: Identify the IT properties that the company is most worried about. Prioritization is usually assigned to properties that promote the organization's agenda and key business objectives.
- Step 2: Identify potential loss cases, risks, and threats, such as a DDoS attack or insider theft.



1. General Security Risk Assessment

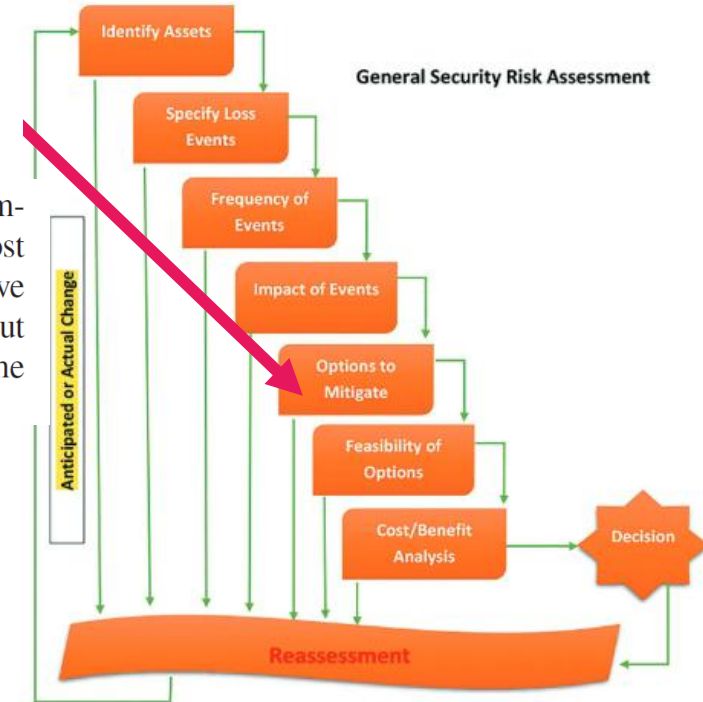
- Step 3: Estimate the number of incidents or the probability of each possible threat; certain risks, such as insider theft, are more likely to occur than others.
- Step 4: Determine the severity of each hazard. Is the danger likely to have a small effect on the enterprise, or does it prevent it from carrying out its task for an extended period of time?

Risk Tolerance Level = Probability x Impact



1. General Security Risk Assessment

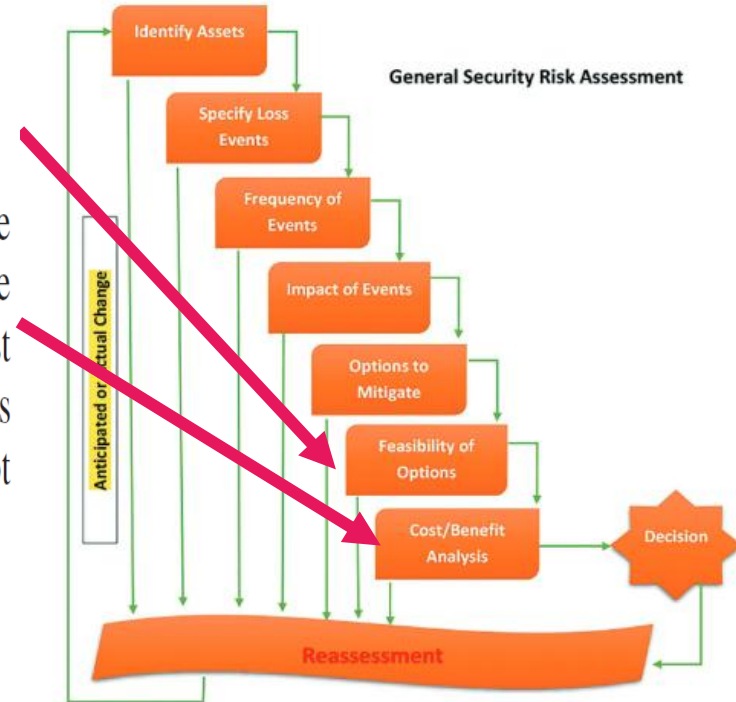
- Step 5: Decide if each hazard can be mitigated so that it is either less likely to occur or has a smaller effect on the company if it does. Installing virus security on all machines, for example, makes it much less likely that a computer may get infected by a virus. Due to time and budget constraints, most organizations tend to concentrate on risks with a high frequency (relative to all other threats) and a high impact (relative to all other threats). To put it another way, start with the risks that are most likely to exist and have the greatest negative effect on the organization.



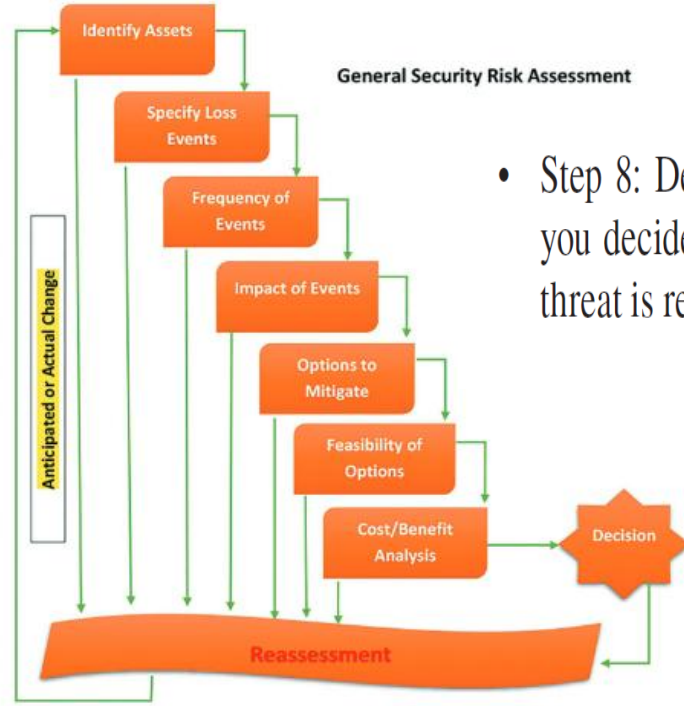


1. General Security Risk Assessment

- Step 6: Evaluate the viability of putting the mitigation options into action.
- Step 7: Conduct a cost-benefit study and guarantee that the activities are profitable. Because no amount of money can ensure a flawless compliance scheme, businesses must weigh the possibility of a security breach against the cost of avoiding one. Fair assurance acknowledges that administrators must exercise their judgment to guarantee that the cost of control does not outweigh the system's gains or threats.



1. General Security Risk Assessment



- Step 8: Determine whether to implement a particular countermeasure. If you decide not to employ a particular countermeasure, think whether the threat is really serious, and if so, choose a less costly option.



1. General Security Risk Assessment

Examples of Risk Analysis (Probability and Impact)	Possible Decision based on Risk Tolerance Level
Scenario 1: Database containing publicly available information has less security controls. Probability of data breach: High Impact due to the data breach: Non-critical since the information from the database is already in the public	Accept the Risk with the current security controls.
Scenario 2: Database containing customer's sensitive information with very high security controls Probability of data breach: Low due to tight security measures. Impact due to the data breach: Critical as it may affect company's reputation and possibly face legal lawsuits and subsequently cause huge financial losses	Prioritize the risk by taking all the necessary actions to avoid the risk from happening.



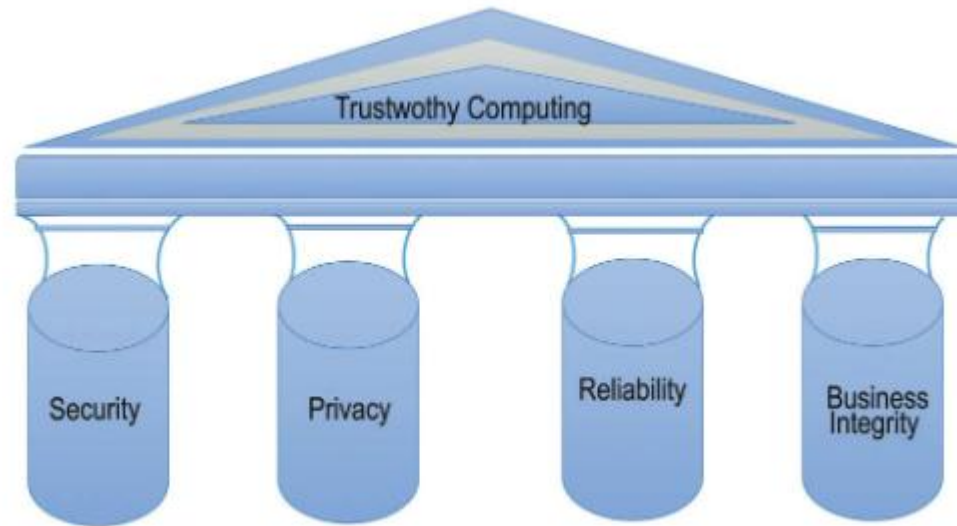
2. Trustworthy Computing

— — —

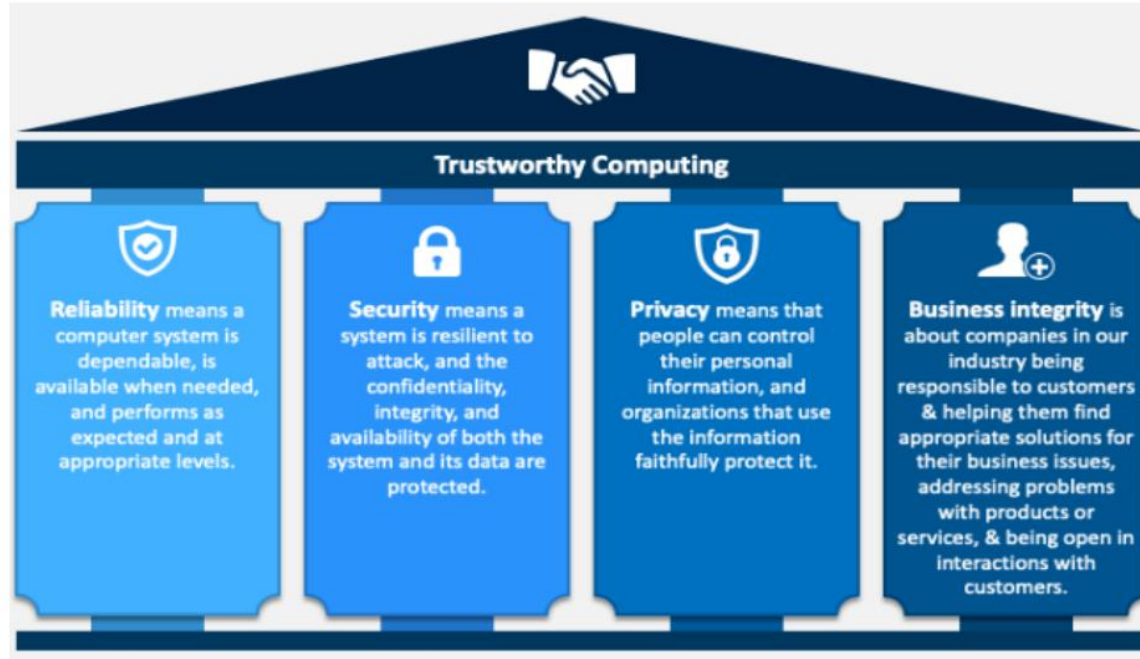
- Trustworthy computing is a computing approach that provides stable, confidential, and consistent computing interactions based on sound market practices
- Trustworthy computing is the top priority for computer industry's (software and hardware designers, contractors, programmers) clients.
- Microsoft, for example, has committed to a trustworthy programming campaign to increase confidence in its tech offerings as shown in the figure in the following slide.

2. Trustworthy Computing

— — —



2. Trustworthy Computing



Source:
<https://www.ijfans.org/uploads/paper/68279996ad0645f70c14f78915979422.pdf>

3. CIA Triad

— — —



CIA Triad Principle	Description
Confidentiality	Only approved individuals should be able to access sensitive information. For example, the credit card number used to make an online purchase must be kept secure and unavailable to unapproved entities. Confidentiality ensures that only authorized parties can view the information. Providing confidentiality can involve several security tools, ranging from software to encrypt the credit card number stored on the web server to door locks to prevent access to those servers.

3. CIA Triad

— — —



CIA Triad Principle	Description
Integrity	Integrity ensures that the information is correct and no unauthorized person or malicious software has altered the data. In the example of an online purchase, an attacker who could change the amount of a purchase from \$10,000.00 to \$1.00 would violate the integrity of the information

3. CIA Triad

— — —



CIA Triad Principle	Description
Availability	A state of the environment in which designated users have constant access to said assets. Availability ensures that data is accessible to only authorized users and not to unapproved individuals. For example, the total number of items ordered as the result of an online purchase must be made available to an employee in a warehouse so that the correct items can be shipped to the customer.



4. IT Security Policy

— — —

- The IT Security Policy is a written document that states how an organization plans to protect the company's information technology assets.
- Examples of IT Security Policy adopted by companies (non-exhaustive list):

IT Security Policy	Description
Acceptable Use Policy (AUP)	Provides network and system users with clear direction on permissible uses of information resources
Information Security Policy	Provides high-level authority and guidance for the security program



4. IT Security Policy

— — —

- Examples of IT Security Policy adopted by companies (non-exhaustive list): (Cont.):

IT Security Policy	Description
Incident Response Policy	Describes how the organization will respond to security incidents.
Business Continuity and Disaster Recovery Policy	Outline the procedures and strategies to ensure that essential business functions continue to operate during and after a disaster, and that data and assets are recovered and protected.



4. IT Security Policy

— — —

- Examples of IT Security Policy adopted by companies (non-exhaustive list):(Cont.):

IT Security Policy	Description
Software Development Life Cycle (SDLC) Policy	Establishes the processes and standards for maintaining software, ensuring that security is considered and integrated at every stage of development.
Change Management and Change Control Policy	Describe how the organization will review, approve, and implement proposed changes to information systems in a manner that manages both cyber security and operational risk.



4. IT Security Policy

— — —

- More examples of IT Security Policies adopted by companies:
<https://www.icims.com/wp-content/uploads/2021/09/IT-Security-Policy-6SEPTEMBER2021.pdf>



5. International Organization for Standardization (ISO)

— — —

- The [International Organization for Standardization \(ISO\)](#) has created a wide array of cybersecurity standards.
- ISO 27001 is a standard that provides requirements for an information security management system (ISMS). An ISMS is a systematic approach to managing sensitive assets so that they remain secure. These assets include the people, processes, and IT systems used to manage risk.



5. International Organization for Standardization (ISO)

— — —

- ISO 27001 includes control objectives covering 14 categories:
 - Information Security Policies
 - Organization of information security
 - Human resource security
 - Asset Management
 - Access Control
 - Cryptography
 - Physical and environmental security
 - Operation Security
 - Communications Security



5. International Organization for Standardization (ISO)

— — —

- ISO 27001 includes control objectives covering 14 categories (Cont.):
 - System acquisition, development and maintenance
 - Supplier relationships
 - Information security incident management
 - Information security aspects of business continuity management
 - Compliance with internal requirements, such as policies, and with external requirements, such as laws



6. National Institute of Standards and Technology (NIST)

— — —

- The [National Institute of Standards and Technology \(NIST\)](#) operates under the U.S. Commerce Department, with the mission to promote U.S. innovation and industrial competitiveness by **advancing measurement science, standards, and technology** in ways that enhance economic security and improve our quality of life.
- NIST created the **NIST cybersecurity frameworks** as a set of guidelines for helping private companies identify, detect, and respond to cyberattacks.
- These frameworks also include guidelines for how to prevent and recover from an attack.
- The latest version for the NIST Cybersecurity Framework is [NIST CSF 2.0](#).



6. National Institute of Standards and Technology (NIST)

— — —

- The NIST cybersecurity frameworks are divided into three basic parts (Cont.)
 - **CSF Organizational Profiles**. Profiles relate to the current status of the organization's cybersecurity measures and the "road maps" toward compliance with the NIST cybersecurity framework. Profiles are like an executive summary of everything an organization has done for the NIST cybersecurity framework, and they can help demonstrate how each function, category, or subcategory can increase security. These profiles allow organizations to see their vulnerabilities at each step; once the vulnerabilities are mitigated, the organization can move up to higher implementation tiers.



6. National Institute of Standards and Technology (NIST)

— — —

- The NIST cybersecurity frameworks are divided into three basic parts (Cont.)
 - **CSF Organizational Profiles** (Cont.)
 - Every Organizational Profile includes one or both of the following:
 - A **Current Profile** specifies the Core outcomes that an organization is currently achieving (or attempting to achieve) and characterizes how or to what extent each outcome is being achieved.
 - A **Target Profile** specifies the desired outcomes that an organization has selected and prioritized for achieving its cybersecurity risk management objectives. A Target Profile considers anticipated changes to the organization's cybersecurity posture, such as new requirements, new technology adoption, and threat intelligence trends.

6. National Institute of Standards and Technology (NIST)

- The NIST cybersecurity frameworks are divided into three basic parts (Cont.)
 - **CSF Organizational Profiles** (Cont.)
 - Steps for creating and using a CSF Organizational Profile.



Main Source (pg 6-7):

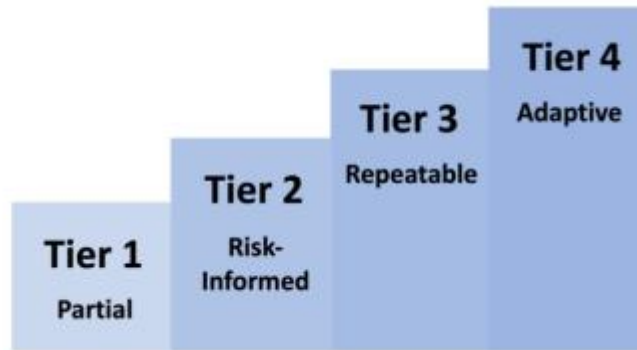
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

Supplementary Source:

https://medium.com/@root_63330/enhancing-your-organisation-security-with-nist-csf-2-0-d82b1235c00a

6. National Institute of Standards and Technology (NIST)

- The NIST cybersecurity frameworks are divided into three basic parts (Cont.)
 - **CSF Tiers.** The NIST framework specifies four CSF tiers that help organizations identify their level of compliance: the higher the tier, the more compliant the organization.



Main Source (pg 7-8):

<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

Supplementary Source:

https://medium.com/@root_63330/enhancing-your-organisation-security-with-nist-csf-2-0-d82b1235c00a



Question?

"Ethics is knowing the difference between what you have a right to do and what is right to do." - Potter Stewart



Disclaimer:

The slide content has been sourced from the following reference books and Internet resources. Refer to the following list for more details and further reading:

1. Awari, G.K., & Warjukur, S.V. (2022). *Ethics in Information Technology: A Practical Guide*. CRC Press, Taylor & Francis Group.
2. Ciampa, M.D. (2022). *CompTIA Security+ Guide To Network Security Fundamentals*. 7th ed. Cengage.
3. Chapple, M. (2023). *CompTIA Security+ Study Guide: Exam SY0-701*. 9th ed. John Wiley.
4. Khan, G. (2012). A comprehensive study on Trustworthy Computing.
<https://www.ijfans.org/uploads/paper/68279996ad0645f70c14f78915979422.pdf>
5. NIST. (2022). About NIST. <https://www.nist.gov/about-nist>
6. NIST. (2024). The NIST Cybersecurity Framework (CSF) 2.0.
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

Please note that the slides' content is subject to changes and updates.